Remediation Plan

TRACEGUARD | Evidence snapshot

Schema Version
1.0

Bundle Id
bbf6ace3-5b75-45e9-a295-f7c61bdbd718

Generated At
2026-10-31T23:24:16.148Z

Advisory Snapshot Id
0e4a4fe12d10370e464dbdf402562d7c3d52eab95546462ee7a4a6df35c7b3b0

Inventory Counts

Project Modules
1

Unique Packages
7

Unique Package Versions
8

Dependency Instances
8

Direct Dependencies
4

Transitive Only Dependencies
4

Unknown Relationships
0

Dependency Edges
8

Unresolved Declarations
0

Scan Evidence

Scanner Version
0.2.0

Archive Sha256
cc54816c50928cb5739509bfab8a5b72d36a5d53210154431af03c742efd4b65

Revision Status
unknown

Inventory Sha256
147361aa36811031dfadd65a336aa4d86b4ec3144fe6219fc8577d403100ee6f

Languages

1.
JavaScript

Projects

1.

Path
.

Manager
npm

Status
analyzed

Reasons
(none recorded)

2.

Path
.

Manager
npm

Status
analyzed

Reasons
(none recorded)

Metadata Hashes

1.

Path
package-lock.json

Sha256
4fbdfb16d2b682fd3486d2442abbbe415ddf24885d179ced7e644ace6f754e5c

2.

Path
package.json

Sha256
391c2de4bdacd91dd036293de3b7479fae6dbda0ab468fb2d928b58cad24a80c

Scan

Id
1f4d8678-6b9f-4152-ae6c-6293337445dc

Source
ZIP upload

Created At
2026-10-31T23:24:12.175Z

Inventory Sha256
147361aa36811031dfadd65a336aa4d86b4ec3144fe6219fc8577d403100ee6f

Coverage

Status
complete

Checked At
2026-10-31T23:24:12.185Z

Package Instances
8

Matched
2

No Known Match
6

Unknown
0

Findings Included
2

Findings Omitted
0

Limitations

1.
This report is a point-in-time snapshot of the saved inventory and fresh OSV queries, not a live deployment assessment.

2.
Dependency presence and advisory version matches do not prove runtime execution, attacker control, or actual exploitability.

3.
No known advisory match is not a safety guarantee. Unknown, failed, paginated, or skipped checks are not clean findings.

4.
Advisory IDs can be aliases of the same underlying issue; counts describe package instances, not distinct exploitable vulnerabilities.

5.
Details are fetched for at most 40 unique advisory IDs; at most 100 matched package instances and 20 advisory IDs per finding are included. Descriptions, references, paths and source evidence are bounded.

6.
Source-provided CVSS vectors are retained without inventing numeric scores or priorities. Withdrawn or mismatched records require manual review.

7.
A verified candidate is an advisory-listed fixed release that exists in its ecosystem registry and returns no known OSV match at verification time. It is not a guarantee of safety, compatibility, or that every relevant fix was published.

8.
At most three candidate releases per package/version are checked, for at most 20 unique pairs. If no candidate is verified, manual review is required. Major-version changes may require migration.

9.
Transitive updates require changes to the owning dependency declaration or parent. No dependency graph or lockfile is changed automatically.

10.
Only server-recorded scoped reachability results from this server process are included (latest result per instance, at most 100 instances per scan and 100 recent scans; not restored after restart). Their affected-export mappings are user-declared; NOT REACHABLE applies only within each declared coverage and is never a global safety claim.

11.
No source code, submitted package scripts, or package installation is executed while preparing these reports. Testing and release-note review remain the maintainer's responsibility.

Report Type
remediation-plan

Title
Remediation Plan

Actions

1.

Finding Id
F-001

Package Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Package Name
lodash

Installed Version
4.17.20

Status
MANUAL REVIEW

Verification

Checked At
2026-10-31T23:24:19.703Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-29mw-wpgm-hmr9

2.
https://api.osv.dev/v1/vulns/GHSA-35jh-r3h4-6jhm

3.
https://api.osv.dev/v1/vulns/GHSA-f23m-r3pf-42rh

4.
https://api.osv.dev/v1/vulns/GHSA-r5fr-rjxr-66jc

5.
https://api.osv.dev/v1/vulns/GHSA-xxjr-mmjv-4gpg

Candidate Advisory Status
not-verified

Compatibility
NOT TESTED

Steps

1.
No publishable, advisory-clean upgrade candidate could be verified within the report coverage. Do not assume that latest, a fixed boundary, or an unavailable query is safe.

2.
Review the cited advisories for lodash@4.17.20, published maintainer fixes, and all owning parent paths. Verify a compatible release before choosing an upgrade.

3.
If no supported fix exists, evaluate removing or replacing the dependency, disabling the affected feature, or applying a maintainer-reviewed patch. These are manual options, not verified mitigations.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.
Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-29mw-wpgm-hmr9

2.
https://nvd.nist.gov/vuln/detail/CVE-2020-28500

3.
https://github.com/github/advisory-database/pull/6139

4.
https://github.com/lodash/lodash/pull/5065

5.
https://github.com/lodash/lodash/pull/5065/commits/02906b8191d3c1 00c193fe6f7b27d1c40f200bb7

6.
https://github.com/lodash/lodash/commit/c4847ebe7d14540bb28a8b932 a9ce1b9ecbfee1a

7.
https://www.oracle.com/security-alerts/cpuoct2021.html

8.
https://www.oracle.com/security-alerts/cpujul2022.html

9.
https://www.oracle.com/security-alerts/cpujan2022.html

10.
https://www.oracle.com//security-alerts/cpujul2021.html

11.
https://snyk.io/vuln/SNYK-JS-LODASH-1018905

12.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074893

13.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074895

14.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074892

15.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074894

16.
https://osv.dev/vulnerability/GHSA-35jh-r3h4-6jhm

17.
https://nvd.nist.gov/vuln/detail/CVE-2021-23337

18.
https://github.com/lodash/lodash/commit/3469357cff396a26c363f8c1b 5a91dde28ba4b1c

19.
https://snyk.io/vuln/SNYK-JS-LODASH-1040724

20.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSNPM-1074929

21.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWERGITHUBLODASH-1074931

22.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARSBOWER-1074928

23.
https://snyk.io/vuln/SNYK-JAVA-ORGWEBJARS-1074930

24.
https://snyk.io/vuln/SNYK-JAVA-ORGFUJIONWEBJARS-1074932

25.
https://security.netapp.com/advisory/ntap-20210312-0006

26.
https://github.com/rubysec/ruby-advisory-db/blob/master/gems/loda sh-rails/CVE-2021-23337.yml

27.
https://osv.dev/vulnerability/GHSA-f23m-r3pf-42rh

28.
https://github.com/lodash/lodash/security/advisories/GHSA-f23m-r3pf-42rh

29.
https://github.com/lodash/lodash/security/advisories/GHSA-xxjr-mmjv-4gpg

30.
https://nvd.nist.gov/vuln/detail/CVE-2026-2950

31.
https://github.com/lodash/lodash

32.
https://osv.dev/vulnerability/GHSA-r5fr-rjxr-66jc

33.
https://github.com/lodash/lodash/security/advisories/GHSA-r5fr-rjxr-66jc

34.
https://nvd.nist.gov/vuln/detail/CVE-2026-4800

35.
https://cna.openjsf.org/security-advisories.html

36.
https://github.com/advisories/GHSA-35jh-r3h4-6jhm

37.
https://osv.dev/vulnerability/GHSA-xxjr-mmjv-4gpg

38.
https://nvd.nist.gov/vuln/detail/CVE-2025-13465

39.
https://github.com/lodash/lodash/commit/edadd452146f7e4bad4ea684e 955708931d84d81

40.
https://cert-portal.siemens.com/productcert/html/ssa-253495.html

41.
https://docs.npmjs.com/cli/v11/commands/npm-install/

42.
https://docs.npmjs.com/cli/v11/configuring-npm/package-json/#overrides

43.
https://docs.npmjs.com/cli/v11/commands/npm-explain/

2.

Finding Id
F-002

Package Node Id
urn:traceguard:component:cbeff0b767fcc8148a21020df309d840d73aa24d ceafc667ce44394a02d5e196

Package Name
minimist

Installed Version
0.0.8

Status
VERIFIED CANDIDATE

Suggested Version
0.2.4

Verification

Checked At
2026-10-31T23:24:19.703Z

Advisory Sources

1.
https://api.osv.dev/v1/vulns/GHSA-vh95-rmgr-6w4m

2.
https://api.osv.dev/v1/vulns/GHSA-xvch-5gv4-984h

Registry Source
https://registry.npmjs.org/minimist/0.2.4

Candidate Advisory Status
no-known

Compatibility
NOT TESTED

Steps

1.
Review the cited advisories and release notes for minimist 0.2.4; compare with installed 0.0.8. Compatibility has not been tested.

2.
In package-lock.json, locate the owning package.json declaration (including aliases) and update its declared dependency to the verified candidate 0.2.4. Preserve the intended runtime/dev/optional role.

3.
Regenerate the affected lockfile in your controlled development environment, review the diff, and ensure every affected installation path is replaced. Do not edit a nested node_modules copy as the fix.

Validation

1.
Run the project's actual regression, integration, and build checks in a trusted environment; resolve major-version migration requirements.

2.
Rescan the updated manifests and lockfiles and rerun OSV checks for all affected instances, including duplicate versions.

3.
Revisit scoped function reachability with verified affected-export mappings. Separately review runtime feasibility, attacker control, deployment exposure, and mitigations.

Recommendation Sources

1.
https://osv.dev/vulnerability/GHSA-vh95-rmgr-6w4m

2.
https://nvd.nist.gov/vuln/detail/CVE-2020-7598

3.
https://github.com/minimistjs/minimist/commit/10bd4cdf49d9686d482 14be9d579a9cdfda37c68

4.
https://github.com/minimistjs/minimist/commit/38a4d1caead72ef99e8 24bb420a2528eec03d9ab

5.
https://github.com/minimistjs/minimist/commit/4cf1354839cb972e384 96d35e12f806eea92c11f#diff-a1e0ee62c91705696ddb71aa30ad4f95

6.
https://github.com/minimistjs/minimist/commit/63e7ed05aa4b1889ec2 f3b196426db4500cbda94

7.
https://github.com/substack/minimist

8.
https://snyk.io/vuln/SNYK-JS-MINIMIST-559764

9.
https://www.npmjs.com/advisories/1179

10.
https://osv.dev/vulnerability/GHSA-xvch-5gv4-984h

11.
https://nvd.nist.gov/vuln/detail/CVE-2021-44906

12.
https://github.com/minimistjs/minimist/issues/11

13.
https://github.com/substack/minimist/issues/164

14.
https://github.com/minimistjs/minimist/pull/24

15.
https://github.com/minimistjs/minimist/commit/34e20b8461118608703 d6485326abbb8e35e1703

16.
https://github.com/minimistjs/minimist/commit/bc8ecee43875261f4f1 7eb20b1243d3ed15e70eb

17.
https://github.com/minimistjs/minimist/commit/c2b981977fa834b223b 408cfb860f933c9811e4d

18.
https://github.com/minimistjs/minimist/commit/ef9153fc52b6cea0744 b2239921c5dcae4697f11

19.
https://github.com/Marynk/JavaScript-vulnerability-detection/blob /main/minimist%20PoC.zip

20.
https://github.com/minimistjs/minimist/commits/v0.2.4

21.
https://github.com/substack/minimist/blob/master/index.js#L69

22.
https://security.netapp.com/advisory/ntap-20240621-0006

23.
https://docs.npmjs.com/cli/v11/commands/npm-install/

24.
https://docs.npmjs.com/cli/v11/configuring-npm/package-json/#overrides

25.
https://docs.npmjs.com/cli/v11/commands/npm-explain/

Package Risk

Checked At
2026-10-31T23:24:19.704Z

Coverage

Total
8

Metadata Checked
8

Unavailable
0

Skipped
0

Results

1.

Node Id
urn:traceguard:component:5b7799002fa8f5baca9f27c7f3068577cfa48d9f 8a1b5f554a6368ee0e1baf89

Name
is-even

Version
1.0.0

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Lock
sha512-LEhnkAdJqic4Dbqn58A0y52IXoHWlsueqQkKfMfdEnIYG8A1sm/GHidKkS 6yvXlMoRrkM34csHnXQtOqcb+Jzg==

Comparison
MATCH

Artifact Verification
NOT PERFORMED

Registry
sha512-LEhnkAdJqic4Dbqn58A0y52IXoHWlsueqQkKfMfdEnIYG8A1sm/GHidKkS 6yvXlMoRrkM34csHnXQtOqcb+Jzg==

Shasum
76b5055fbad8d294a86b6a949015e1c97b717c06

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEQCIGdFCa72n+vIbeujikn3ExFVcAX2rnuKWBBFWQlQIH1gAiBn5HXb7zzOTEFwA
nHX8zrI8+2gPyDaxgy5gAMFq7fzhA==

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/is-even/1.0.0

Metadata

Description
Return true if the given number is even.

License
MIT

Repository
https://github.com/jonschlinkert/is-even.git

Homepage
https://github.com/jonschlinkert/is-even

Maintainers

1.
jonschlinkert

2.
doowb

Lifecycle Scripts

2.

Node Id
urn:traceguard:component:643cd63f0c02afa509c11e8984e066a3c84769a5 f6b21c694c85826f6cb14b52

Name
kind-of

Version
3.2.2

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Lock
sha512-NOW9QQXMoZGg/oqnVNoNTTIFEIid1627WCffUBJEdMxYApq7mNE7CpzucI
Pc+ZQg25Phej7IJSmX3hO+oblOtQ==

Comparison
MATCH

Artifact Verification
NOT PERFORMED

Registry
sha512-NOW9QQXMoZGg/oqnVNoNTTIFEIid1627WCffUBJEdMxYApq7mNE7CpzucI
Pc+ZQg25Phej7IJSmX3hO+oblOtQ==

Shasum
31ea21a734bab9bbb0f32466d893aea51e4a3c64

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEQCIA+PkCBtTWJTJGp6BmBDfGldIMKBbiUOjpqLF17rq5ChAiByW4/OwEAm6P8sM
zKZeuAe6BJfOo7Hw7VOn765GyKKzQ==

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/kind-of/3.2.2

Metadata

Description
Get the native type of a value.

License
MIT

Repository
https://github.com/jonschlinkert/kind-of.git

Homepage
https://github.com/jonschlinkert/kind-of

Maintainers

1.
jonschlinkert

2.
doowb

Lifecycle Scripts

3.

Node Id
urn:traceguard:component:76396b0995214089bf2b58dd03b9a8a648f1386e 96583619f38bb8822aced6c1

Name
is-buffer

Version
1.1.6

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Lock
sha512-NcdALwpXkTm5Zvvbk7owOUSvVvBKDgKP5/ewfXEznmQFfs4ZRmanOeKBTj
RVjka3QFoN6XJ+9F3USqfHqTaU5w==

Comparison
MATCH

Artifact Verification
NOT PERFORMED

Registry
sha512-NcdALwpXkTm5Zvvbk7owOUSvVvBKDgKP5/ewfXEznmQFfs4ZRmanOeKBTj

RVjka3QFoN6XJ+9F3USqfHqTaU5w==

Shasum
efaa2ea9daa0d7ab2ea13a97b2b8ad51fefbe8be

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEUCIDQAnODX01K6w5cJdtd+M5OyeiiFZL0r/VpvrwjdJcEEAiEA1n9Pq+avL75Fr FQdoA84fBlUmeqf25sOcbsEXxHQh7c=

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/is-buffer/1.1.6

Metadata

Description
Determine if an object is a Buffer

License
MIT

Homepage
https://github.com/feross/is-buffer#readme

Maintainers

1.
feross

Lifecycle Scripts

4.

Node Id
urn:traceguard:component:8cec2c0a911ef6a0a4211e07416af7bbbe980813 8060339d463d93f10e00b2e9

Name
is-number

Version
7.0.0

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Lock
sha512-41Cifkg6e8TylSpdtTpeLVMqvSBEVzTttHvERD741+pnZ8ANv0004MRL43 QKPDlK9cGvNp6NZWZUBlbGXYxxng==

Comparison
MATCH

Artifact Verification

NOT PERFORMED

Registry
sha512-41Cifkg6e8TylSpdtTpeLVMqvSBEVzTttHvERD741+pnZ8ANv0004MRL43 QKPDlK9cGvNp6NZWZUBlbGXYxxng==

Shasum
7535345b896734d5f80c4d06c50955527a14f12b

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEUCIGex85Xx5rKhEgNSkg7z5bBu7vbcFbJnWJZbV3f9Td8GAiEA5wzgLXU41sE6e
zCKGrmzsyMtm6M+2OhefJJhkzPEAoc=

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/is-number/7.0.0

Metadata

Description
Returns true if a number or string value is a finite number. Useful for regex matches, parsing, user input, etc.

License
MIT

Repository
https://github.com/jonschlinkert/is-number.git

Homepage
https://github.com/jonschlinkert/is-number

Maintainers

1.
doowb

2.
jonschlinkert

3.
realityking

Lifecycle Scripts

5.

Node Id
urn:traceguard:component:9c005dbc4c51bb6a564f133bc369c7e231f619e1 1fc786d41338c271f12c60e4

Name
lodash

Version
4.17.20

Classification
NO SIGNALS

Metadata Status
available

Signals

(none recorded)

Malicious Sources
(none recorded)

Integrity

Lock
sha512-PlhdFcillOINfeV7Ni6oF1TAEayyZBoZ8bcshTHqOYJYlrqzRK5hagpagk y5o4HfCzzd1TRkXPMFq6cKk9rGmA==

Comparison
MATCH

Artifact Verification
NOT PERFORMED

Registry
sha512-PlhdFcillOINfeV7Ni6oF1TAEayyZBoZ8bcshTHqOYJYlrqzRK5hagpagk y5o4HfCzzd1TRkXPMFq6cKk9rGmA==

Shasum
b44a9b6297bcb698f1c51a3545a2b3b368d59c52

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEUCIQDPF8qtGU3yxHj4Yw4h9hpt+DCVT9dlk9ApvKxVXPwv7AIgSLC2TkL6ONbFl hyV2ZcE4v52ANJMoA/HwKY+zKt9Kh4=

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/lodash/4.17.20

Metadata

Description
Lodash modular utilities.

License
MIT

Repository
https://github.com/lodash/lodash.git

Homepage
https://lodash.com/

Maintainers

1.
bnjmnt4n

2.
jdalton

3.
mathias

Lifecycle Scripts

6.

Node Id
urn:traceguard:component:c3d239051dada03b3f31da6954723755f3af5cb0 8f6550c2e0016d057c57127d

Name
is-number

Version
3.0.0

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Lock
sha512-4cboCqIpliH+mAvFNegjZQ4kgKc3ZUhQVr3HvWbSh5q3WH2v82ct+T2Y1h dU5Gdtorx/cLifQjqCbL7bpznLTg==

Comparison
MATCH

Artifact Verification
NOT PERFORMED

Registry
sha512-4cboCqIpliH+mAvFNegjZQ4kgKc3ZUhQVr3HvWbSh5q3WH2v82ct+T2Y1h dU5Gdtorx/cLifQjqCbL7bpznLTg==

Shasum
24fd6201a4782cf50561c810276afc7d12d71195

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEUCIEpkuzJnkIAtuDMAI3VLqzFNwNANap4m9nyeUneW72kRAiEAtsctBWg1OtEaj
2FSH+9ViALZU1O0hQFCVzwGMWHfVnk=

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/is-number/3.0.0

Metadata

Description
Returns true if the value is a number. comprehensive tests.

License
MIT

Repository
https://github.com/jonschlinkert/is-number.git

Homepage
https://github.com/jonschlinkert/is-number

Maintainers

1.
jonschlinkert

2.
doowb

Lifecycle Scripts

7.

Node Id
urn:traceguard:component:cbeff0b767fcc8148a21020df309d840d73aa24d ceafc667ce44394a02d5e196

Name
minimist

Version
0.0.8

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Lock
sha512-miQKw5Hv4NS1Psg2517mV4e4dYNaO3++hjAvLOAzKqZ61rH8NS1SK+vbfB WZ5PY/Me/
bEWhUwqMghEW5Fb9T7Q==

Comparison
MATCH

Artifact Verification
NOT PERFORMED

Registry
sha512-miQKw5Hv4NS1Psg2517mV4e4dYNaO3++hjAvLOAzKqZ61rH8NS1SK+vbfB WZ5PY/Me/
bEWhUwqMghEW5Fb9T7Q==

Shasum
857fcabfc3397d2625b8228262e86aa7a011b05d

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEYCIQDW7J/Us43W8sxeysKUFk4mJj4B8ZpWxTsPHSc3ma5YHQIhAK2j6GqOYWD1U
cAb6yxa85VuFB1DhhfYHwW0pDeAcBcS

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/minimist/0.0.8

Metadata

Description
parse argument options

License
MIT

Homepage
https://github.com/substack/minimist

Maintainers

1.
substack

Lifecycle Scripts

8.

Node Id
urn:traceguard:component:d179ea038a52817568f89455d9d487570809ba22 986963ec6f6c9039b33a58e0

Name
is-odd

Version
0.1.2

Classification
NO SIGNALS

Metadata Status
available

Signals
(none recorded)

Malicious Sources
(none recorded)

Integrity

Lock
sha512-Ri7C2K7o5IrUU9UEI8losXJCCD/UtsaIrkR5sxIcFg4xQ9cRJXlWA5DQvT E0yDc0krvSNLsRGXN11UPS6KyfBw==

Comparison
MATCH

Artifact Verification
NOT PERFORMED

Registry
sha512-Ri7C2K7o5IrUU9UEI8losXJCCD/UtsaIrkR5sxIcFg4xQ9cRJXlWA5DQvT E0yDc0krvSNLsRGXN11UPS6KyfBw==

Shasum
bc573b5ce371ef2aad6e6f49799b72bef13978a7

Provenance

Status
NOT ADVERTISED

Verification
NOT PERFORMED

Signatures

1.

Keyid
SHA256:jl3bwswu80PjjokCgh0o2w5c2U4LhQAE57gj9cz1kzA

Sig
MEQCIHI63jfRjPRbhpolQPjSEwwTdVf8yV/im1aqm5QrLDrbAiBPeyyXzmbqFY+l6 K7EFNmlKaVmC8rMF7inILRu3jT9NQ==

Review Steps

1.
In a trusted development environment, use npm audit signatures to verify supported registry signatures and provenance. This report has not performed that verification.

Source
https://registry.npmjs.org/is-odd/0.1.2

Metadata

Description
Returns true if the given number is odd.

License
MIT

Repository
https://github.com/jonschlinkert/is-odd.git

Homepage
https://github.com/jonschlinkert/is-odd

Maintainers

1.
jonschlinkert

2.
doowb

Lifecycle Scripts

Limitations

1.
Heuristics are review signals, not proof of malicious intent. NO SIGNALS is not a safety guarantee. Metadata can be publisher-controlled.

2.
Name similarity uses a fixed reference list v1 (react, react-dom, express, lodash, axios, typescript, webpack, vite, eslint, prettier, chalk, commander, mongoose, next, jquery, dotenv), one edit or adjacent transposition, minimum length five; scoped names are excluded. It does not cover all typosquatting or dependency confusion.

3.
At most 100 unique exact package/version pairs and 1,000 instances are included, with a 15-second metadata deadline and 1 MiB response limit. Unavailable or omitted data is not clean.

4.
Integrity compares recorded lock and registry digest strings only. Tarballs, installed bytes, signatures and provenance attestations are not downloaded or cryptographically verified. Matching metadata does not establish safety.

5.
Provenance is registry-advertised evidence only. Missing provenance or signatures does not imply malware. Lifecycle scripts are common in legitimate packages and are never executed.

6.
CONFIRMED MALICIOUS requires a fresh OSV version match and a verified, non-withdrawn MAL- advisory for the same npm package. This is an attributed source verdict, not an independent analysis; other advisory IDs and heuristics cannot confirm malware. Advisory detail coverage limits also apply.

Sources

1.
https://github.com/npm/registry/blob/main/docs/responses/package- metadata.md

2.
https://docs.npmjs.com/viewing-package-provenance/

3.
https://docs.npmjs.com/cli/v11/commands/npm-audit/

4.
https://osv.dev/

Coverage Actions

1.
Validate changes in a trusted development environment. TRACEGUARD does not execute fixes or submitted source code.